

PureTask – Data Processing Addendum (Template)

Version: 2.0

This is a template DPA for execution with PureTask’s vendors and service providers (e.g., Stripe, Supabase, OneSignal, background-check vendors, analytics providers, email/SMS providers, cloud-hosting providers).

This Data Processing Addendum (this “**DPA**”) is entered into between **PureTask LLC**, a California limited liability company (“**Business**,” “**Controller**,” or “**PureTask**”), and [**VENDOR LEGAL NAME**], a [**VENDOR ENTITY TYPE AND JURISDICTION**] (“**Service Provider**,” “**Processor**,” or “**Vendor**”).

This DPA supplements the underlying agreement between PureTask and Vendor (the “**Principal Agreement**”). In the event of any conflict between the Principal Agreement and this DPA with respect to Personal Information, this DPA controls.

Effective Date: [TO BE COMPLETED]

1. Definitions

Capitalized terms used and not otherwise defined herein have the meanings given to them in the Principal Agreement or in applicable Privacy Laws. The following terms:

- **“Applicable Privacy Laws”** means all laws and regulations governing the Processing of Personal Information, including without limitation: the **California Consumer Privacy Act / California Privacy Rights Act (CCPA/CPRA)**, Cal. Civ. Code § 1798.100 et seq.; the **Texas Data Privacy and Security Act (TDPSA)**, Tex. Bus. & Com. Code Ch. 541; the **Florida Digital Bill of Rights (FDBR)**, Fla. Stat. § 501.701 et seq.; the **EU General Data Protection Regulation 2016/679 (GDPR)** and the **UK GDPR** (where applicable); and other applicable U.S. state privacy laws.
 - **“Business,” “Controller,” “Service Provider,” “Contractor,” “Processor,” “Sub-Processor,” “Personal Information,” “Sensitive Personal Information,” “Sell,” “Share,” and “Process”** (and their cognates) have the meanings given to them in the CCPA/CPRA or, where the GDPR applies, the GDPR.
 - **“Data Subject”** means an identified or identifiable natural person whose Personal Information is processed under this DPA.
 - **“Permitted Purpose”** means the specific business purpose(s) for which PureTask discloses Personal Information to Vendor, as set forth in **Schedule 1**.
 - **“Security Incident”** means any unauthorized acquisition, access, use, disclosure, alteration, or destruction of Personal Information.
-

2. Roles of the Parties

2.1 PureTask as Business / Controller

PureTask is the **Business** under CCPA/CPRA (and the **Controller** under GDPR).

2.2 Vendor as Service Provider / Processor

Vendor is the **Service Provider** (or, where applicable, **Contractor**) under CCPA/CPRA (and the **Processor** under GDPR).

2.3 No Sale or Sharing

Vendor shall not Sell or Share Personal Information disclosed by PureTask, except as expressly permitted by this DPA and the Principal Agreement, and only as a Service Provider acting on PureTask's behalf.

2.4 No Retention for Other Purposes

Vendor shall not Retain, Use, or Disclose Personal Information for any purpose other than the **Permitted Purpose** specified in Schedule 1, except as required by law.

2.5 No Combining of Personal Information

Vendor shall not combine Personal Information received from PureTask with Personal Information received from or on behalf of any other person, or collected from Vendor's own interactions with the Data Subject, except as permitted under **Cal. Code Regs. tit. 11, § 7050(b)(2)(B)** or analogous provisions.

3. Processing of Personal Information

3.1 Scope and Instructions

Vendor shall Process Personal Information only:

- a. For the Permitted Purpose;
- b. In accordance with PureTask's documented instructions; and
- c. In compliance with Applicable Privacy Laws.

If Vendor believes any instruction from PureTask violates Applicable Privacy Laws, Vendor shall promptly notify PureTask.

3.2 Description of Processing

The categories of Personal Information, categories of Data Subjects, duration of Processing, and nature and purpose of Processing are set forth in **Schedule 1**.

3.3 Confidentiality

Vendor shall ensure that personnel authorized to Process Personal Information are bound by confidentiality obligations.

4. Security

4.1 Security Measures

Vendor shall implement and maintain appropriate technical and organizational measures to protect Personal Information against accidental or unlawful destruction, loss, alteration, unauthorized disclosure, or access. At a minimum, Vendor shall:

- a. Encrypt Personal Information **in transit** using TLS 1.2 or higher;
- b. Encrypt **Sensitive Personal Information at rest** (including government identifiers, tax identifiers, financial account numbers, biometric data, and precise geolocation);
- c. Implement **role-based access controls** and least-privilege access;
- d. Maintain **audit logging** of access to Personal Information;
- e. Conduct regular **vulnerability scanning** and timely patching;
- f. Conduct regular **employee security training** at hire and at least annually thereafter;
- g. Maintain a **written information security program** and a **documented incident response plan**, both reviewed at least annually;
- h. Conduct **background checks** on personnel with access to Personal Information, where lawful;
- i. Maintain **secure backup procedures** with encryption and offsite storage;

- j. Implement **physical security controls** at any facility storing Personal Information;
- k. Use **secure software development lifecycle (SSDLC)** practices, including code review and security testing.

4.2 Certifications and Audit Cadence

Vendor shall maintain industry-standard security certifications and provide PureTask with summary reports on the following cadence:

Certification	Required	Cadence of Renewal
SOC 2 Type II	Required for Vendors processing Sensitive Personal Information or > 100,000 Data Subject records	Annually
ISO 27001	Acceptable alternative or supplement to SOC 2	Tri-annually (with annual surveillance audits)
PCI DSS	Required for Vendors processing payment-card data	Annually
HIPAA Security Rule attestation	Required if any health-related data is processed (not currently expected)	Annually
FedRAMP	Not required, but accepted where applicable	Annually

Vendor shall provide PureTask with the most recent attestation report or executive summary upon execution of this DPA and annually thereafter.

4.3 Insurance Requirements

Vendor shall maintain, at its own cost, the following minimum insurance coverage at all times during the term of the Principal Agreement and this DPA:

- **Cyber Liability / Privacy Liability** — minimum **\$2,000,000 per occurrence and \$5,000,000 aggregate**, covering data breaches, regulatory fines (to the extent insurable), notification costs, forensics, and Data Subject claims;
- **Technology Errors & Omissions** — minimum **\$2,000,000 per claim**, for failures of Vendor's services;
- **Commercial General Liability** — minimum **\$1,000,000 per occurrence and \$2,000,000 aggregate**;
- **Workers' Compensation** — as required by law in Vendor's jurisdiction of operation.

Vendor shall provide PureTask with a Certificate of Insurance upon execution of this DPA and annually upon renewal. Vendor shall notify PureTask of any material change or cancellation within **15 days**. Vendor shall name PureTask as an additional insured under the Cyber Liability and Tech E&O policies where reasonably available.

5. Sub-Processors

5.1 Authorized Sub-Processors

Vendor may engage Sub-Processors only:

- a. Pursuant to a written contract that imposes data-protection obligations no less protective than those in this DPA; and
- b. After providing PureTask with written notice (which may be by email or via a published Sub-Processor list).

A current list of authorized Sub-Processors is set forth in **Schedule 2** (or maintained at **[VENDOR'S URL FOR SUB-PROCESSOR LIST]**).

5.2 Right to Object

PureTask may object to a new Sub-Processor within **15 days** of notice. If PureTask objects on reasonable data-protection grounds, the parties shall work together in good faith to find an alternative; if no resolution, PureTask may terminate the affected services without penalty.

5.3 Liability for Sub-Processors

Vendor remains liable for the acts and omissions of its Sub-Processors as if they were Vendor's own.

6. Data Subject Rights

6.1 Cooperation

Vendor shall reasonably cooperate with PureTask, at no additional cost (or, if a separate cost applies, as specified in the Principal Agreement), in responding to Data Subject requests under Applicable Privacy Laws, including requests to:

- Know, access, or obtain a copy of Personal Information;
- Correct inaccurate Personal Information;
- Delete Personal Information;
- Opt out of Sale, Sharing, or targeted advertising;
- Limit the use of Sensitive Personal Information;
- Appeal a denial of any of the foregoing.

6.2 Direct Requests to Vendor

If Vendor receives a Data Subject request directly, Vendor shall promptly (within **5 business days**) forward the request to PureTask without responding (unless required by law).

7. Audits

7.1 Audit Rights

PureTask, upon at least **30 days'** prior written notice (shorter notice in case of a material Security Incident or regulatory request), and not more than **once per calendar year** (unless a Security Incident or regulator demands more), may audit Vendor's compliance with this DPA, including by reviewing Vendor's security certifications, policies, and procedures.

7.2 Audit Conduct

Audits shall be conducted during normal business hours, at PureTask's expense (unless material non-compliance is found, in which case Vendor bears reasonable audit costs), and subject to mutual confidentiality.

7.3 Alternative

In lieu of an on-site audit, Vendor may satisfy this Section 7 by providing PureTask with a current **SOC 2 Type II** report or equivalent third-party attestation.

8. Security Incidents and Regulatory Cooperation

8.1 Notification

Vendor shall notify PureTask of any **Security Incident** without undue delay and in any event within **forty-eight (48) hours** of becoming aware of it.

8.2 Information Provided

The notice shall include, to the extent known:

- a. The nature of the Security Incident, including the categories and approximate number of Data Subjects and records affected;

- b. The likely consequences;
- c. The measures taken or proposed to address it and mitigate adverse effects;
- d. The name and contact details of Vendor's data protection contact.

8.3 Cooperation in Investigation and Response

Vendor shall cooperate with PureTask in investigating the Security Incident, including:

- a. Providing PureTask with access to Vendor's logs, records, and personnel reasonably necessary to investigate;
- b. Preserving evidence (logs, system images, forensic artifacts) for at least **two (2) years**;
- c. Engaging a qualified forensic investigator at Vendor's expense if the Security Incident is attributable to Vendor's acts or omissions;
- d. Coordinating remediation, including patching, credential rotation, and Sub-Processor management;
- e. Providing regular status updates (no less frequently than weekly during active investigation).

8.4 Notification of Data Subjects and Regulators

Vendor shall cooperate with PureTask in notifying affected Data Subjects and regulators as required by Applicable Privacy Laws, including **Cal. Civ. Code § 1798.82, Tex. Bus. & Com. Code § 521.053, Fla. Stat. § 501.171**, and GDPR Articles 33 and 34. **PureTask retains sole authority** over the content, timing, and method of any Data Subject or regulator notice, except where Vendor is independently required by law to notify (in which case Vendor shall inform PureTask in advance to the extent permitted).

8.5 Regulatory Inquiries and Investigations

If Vendor receives any inquiry, complaint, subpoena, or other communication from a privacy regulator (including the California Privacy Protection Agency, the California Attorney General, the Texas

Attorney General, the Florida Attorney General, the FTC, the CFPB, or any state or federal data-protection authority) **related to Personal Information processed under this DPA**, Vendor shall:

- a. Notify PureTask **within 3 business days** of receipt (or sooner if required by law);
- b. Not respond substantively to the inquiry without first consulting with PureTask, except to the extent legally required to provide preliminary acknowledgment;
- c. Cooperate with PureTask's response strategy, including providing documents, witnesses, and information PureTask reasonably requests;
- d. Coordinate with PureTask's counsel where appropriate.

8.6 No Acknowledgment of Fault

Notification of a Security Incident is not an acknowledgment by Vendor of fault or liability.

9. International Transfers

9.1 Transfer Mechanism

If Vendor Processes Personal Information that originates in the EEA, UK, or Switzerland, the parties agree to the **Standard Contractual Clauses (SCCs)** issued by the European Commission (Decision 2021/914) and, for UK transfers, the **UK International Data Transfer Addendum**, both incorporated by reference, with the following module:

- **Module Two (Controller to Processor)**: PureTask is the data exporter; Vendor is the data importer.

9.2 Onward Transfers

Onward transfers to Sub-Processors are permitted only if Sub-Processors are bound to SCC-equivalent obligations.

10. Deletion or Return of Personal Information

10.1 At Termination

Upon termination or expiration of the Principal Agreement, Vendor shall, at PureTask's option, either:

- a. Return all Personal Information to PureTask in a structured, commonly used, machine-readable format; or
- b. Securely delete all Personal Information, including from backups (subject to commercially reasonable backup-overwrite timelines, not to exceed **180 days**).

10.2 Certification

Vendor shall certify in writing the completion of return or deletion within **30 days** of termination.

10.3 Retention Required by Law

Vendor may retain Personal Information to the extent and for as long as required by law, provided that such Personal Information is held in encrypted form, access is restricted, and no further Processing occurs other than retention.

11. Liability and Indemnification

The parties' liability under this DPA is governed by the limitation-of-liability provisions of the Principal Agreement, except that the limitation **does not apply** to liability arising from:

- a. Vendor's breach of Section 2 (no Sale, Sharing, or unauthorized use);
- b. Vendor's breach of Section 4 (Security) resulting in a Security Incident; or
- c. Either party's indemnification obligations under Applicable Privacy Laws.

Vendor shall **indemnify PureTask** for any regulatory fines, penalties, and Data Subject claims arising from Vendor's breach of this DPA, including reasonable attorneys' fees, subject to the limitations referenced above. PureTask shall promptly notify Vendor of any such claim, allow Vendor to control the defense (with reasonable cooperation), and not settle without Vendor's consent (not to be unreasonably withheld).

12. General Provisions

12.1 Term

This DPA is effective on the Effective Date and continues for the duration of the Principal Agreement. Sections 4, 8, 10, and 11 survive termination as necessary.

12.2 Governing Law

The law specified in the Principal Agreement, or if none, California law.

12.3 Severability

If any provision is unenforceable, the remainder remains in effect.

12.4 Order of Precedence

In the event of conflict: (1) the SCCs (for EEA/UK transfers); (2) this DPA; (3) the Principal Agreement.

12.5 Counterparts; Electronic Signatures

This DPA may be executed in counterparts. Electronic signatures have the same effect as handwritten.

12.6 Entire Agreement

This DPA, together with the Principal Agreement and Schedules, constitutes the entire agreement regarding Vendor's Processing of Personal Information on PureTask's behalf.

Signatures

PURETASK LLC

By: _____ Name: Nathan Chiaratti Title:
Member Date: _____

[VENDOR LEGAL NAME]

By: _____ Name: _____
_____ Title: _____
Date: _____

Schedule 1 – Description of Processing

Item	Description
Permitted Purpose(s)	[E.g., "Process payments and payouts on PureTask's behalf using Stripe Connect Express; perform fraud-risk scoring on transactions; issue IRS Form 1099-K to Pros where required."]
Categories of Data Subjects	Clients (end consumers); Pros (independent contractors); other Platform Users.

Item	Description
Categories of Personal Information	[Tailor per vendor — examples: identifiers, contact info, transaction information, IP address, device identifiers, geolocation, government ID (background-check vendor only), tax identifiers (Stripe only), payment-card tokens (Stripe only).]
Categories of Sensitive Personal Information	[Tailor — examples: last 4 of SSN/Tax ID (Stripe and background-check vendor); government-ID images (background-check vendor); precise geolocation during active GPS check-in.]
Frequency of Processing	Continuous
Duration of Processing	For the term of the Principal Agreement, plus any post-termination retention period required by law (typically up to 7 years for financial records).
Nature of Processing	[E.g., “Collection, storage, transmission, security monitoring, fraud detection, tax reporting.”]

Schedule 2 – Authorized Sub-Processors (as of Effective Date)

Sub-Processor Name	Function	Location
[E.g., AWS]	Cloud hosting	United States

Sub-Processor Name	Function	Location
[E.g., Datadog]	Monitoring and logging	United States
[E.g., Plaid]	Bank verification	United States

Vendor will maintain a current list of Sub-Processors at [URL] and notify PureTask of changes per Section 5.1.

Schedule 3 – Vendor-Specific Notes (Optional)

[Use this schedule for vendor-specific clarifications. Examples: - For **Stripe**: Stripe is the “Business” for its own credit-card and fraud-prevention data, and a “Service Provider” for the payment-facilitation services delivered to PureTask. - For **background-check vendors**: note their additional FCRA obligations as Consumer Reporting Agencies and their separate FCRA contract. - For **OneSignal / Twilio**: note their adherence to CTIA Messaging Best Practices and TCPA recordkeeping obligations. - For **AWS / cloud-hosting**: note any region restrictions, data-residency requirements, and shared-responsibility model.]

This document is a general template. It is not legal advice. DPAs vary by vendor and by privacy law. Please have a licensed attorney review and tailor each DPA before execution. Note that most large vendors (Stripe, AWS, OneSignal, Twilio, Checkr) publish their own DPAs; you may need to accept their form, mark it up, or add a supplement.